

شركة دايموند لوساطة التأمين
سياسة إدارة الوصول
مايو 2025

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة إدارة الوصول			عنوان السياسة	
مُستحدثة			حالة السياسة	
برنامج أمن المعلومات - مسؤوليات سياسة الأمن السيبراني - سياسة تطوير وقبول أنظمة - سياسة إدارة شبكة			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
1ITM0012			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
إدارة تقنية المعلومات			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
الإدارة	الوظيفة	الأسم	التاريخ	التوقيع
الإدارة الرقابية	مدير إدارة الالتزام والامتثال	تركي عبد الله العبدلي	29/07/2025	
رئيس مراجعة السياسات	مدير إدارة الجودة والتطوير	شادن سلطان العتيبي	29/07/2025	
اعتماد السياسة				
الإدارة العليا	العضو المنتدب	بدر سعد الشايع	29/07/2025	



إدارة الجودة والتطوير

Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة إدارة الوصول جزءًا أساسيًا في إطار الحوكمة التقنية، وتهدف إلى ضبط وتوثيق عملية منح وإدارة الصلاحيات للمستخدمين داخل الأنظمة التقنية في الشركة. وتوفر هذه السياسة الإطار التنظيمي الذي يضمن الاستخدام الآمن والمنضبط لحسابات المستخدمين، ويمنع الوصول غير المصرح به أو الاستغلال الخاطئ للصلاحيات داخل البيئة الرقمية للشركة.

2. الهدف من السياسة:

- 2.1 تتفق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو تنظيم إجراءات منح وتعديل وإلغاء صلاحيات الوصول إلى الأنظمة التقنية التابعة للشركة، وذلك بما يضمن الالتزام بتطبيق مبدأ أقل صلاحية (Least Privilege) وفصل المهام (Segregation of Duties).
- 2.2 تقليل المخاطر الناتجة عن إساءة استخدام الحسابات أو الوصول غير المصرح به، مع توثيق دورة حياة الصلاحيات بدءًا من إنشائها وحتى إلغائها. وتأتي هذه السياسة أيضًا امتثالًا للتعليمات التنظيمية الصادرة عن الجهات الرقابية المختصة في المملكة العربية السعودية.

3. تعاريف:

- 3.1 دايموند: شركة الوثيقة الماسية لوساطة التأمين.
- 3.2 المستخدم (User): أي موظف، متدرب، استشاري، مورد، أو طرف ثالث مُخول باستخدام أحد أنظمة الشركة التقنية.
- 3.3 الحساب (Account): معرف إلكتروني فريد يُستخدم للوصول إلى نظام معين ويُربط باسم مستخدم وصلاحيات محددة.
- 3.4 الصلاحية (Privilege): مستوى التحكم أو الوظائف التي يُسمح للمستخدم بتنفيذها داخل النظام (مثل: عرض، تعديل، حذف، اعتماد).
- 3.5 الوصول (Access): عملية دخول المستخدم إلى أحد أنظمة الشركة باستخدام بيانات الدخول المعتمدة لأداء المهام.
- 3.6 الصلاحية المؤقتة (Temporary Access): صلاحية تُمنح لمستخدم لفترة محدودة بهدف تنفيذ مهام محددة، ويتم إلغاؤها تلقائيًا بانتهاء المدة.
- 3.7 الحساب الخارجي (External Account): حساب يُمنح لطرف لا يتبع للهيكل التنظيمي للشركة (مثل شركة تأمين أو مزود خدمة)، ويتم التحكم به وفق اتفاقية دخول.
- 3.8 مبدأ أقل صلاحية (Least Privilege): مبدأ أمني يقضي بمنح المستخدمين الحد الأدنى من الصلاحيات اللازمة فقط لأداء مهامهم.
- 3.9 فصل المهام (Segregation of Duties): ضابط رقابي يقضي بعدم منح شخص واحد صلاحيات متضاربة قد تؤدي إلى استغلال الصلاحية، مثل التنفيذ والموافقة في نفس النظام.
- 3.10 الحساب الإداري (Privileged Account):
- 3.11 حساب يمنح صلاحيات متقدمة مثل إنشاء مستخدمين أو إدارة النظام ويخضع لرقابة مشددة.
- 3.12 Break Glass Account: حساب يُستخدم فقط في حالات الطوارئ القصوى ويتم تفعيله يدويًا مع تسجيل وتوثيق كامل.
- 3.13 سجل الوصول (Access Log): سجل إلكتروني يُوثق كل محاولات الدخول الناجحة أو الفاشلة، والتعديلات التي تتم على الحسابات والصلاحيات.
- 3.14 سجل التعديلات (Access Change Log): سجل مفصل يحتوي على كل العمليات التي يتم فيها منح، تعديل، أو إلغاء الصلاحيات، مع تحديد السبب والتاريخ والمسؤول المنفذ.
- 3.15 نظام MDM: اختصار لـ Mobile Device Management، وهو نظام لإدارة ومراقبة الأجهزة المحمولة التي تصل إلى أنظمة الشركة.
- 3.16 مراجعة الامتثال (Compliance Review): عملية تدقيق دورية للتحقق من مدى التزام المستخدمين بتطبيق سياسة إدارة الوصول ومعالجة المخالفات.

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على جميع أنظمة وتقنيات الشركة، بما في ذلك: أنظمة علاقات العملاء (CRM)، أنظمة الموارد البشرية، بوابات شركات التأمين، أنظمة إصدار الوثائق، البريد الإلكتروني، والأنظمة المرتبطة بالجهات الرقابية مثل مؤسسة النقد وهيئة التأمين.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات. قسم الأمن السيبراني.

6. الكيانات ذات العلاقة:

6.1 كافة الكيانات المملوكة بالكامل إلى شركة داي몬드.

6.2 المزودون التقنيون المعتمدون.

6.3 الجهات الرقابية (هيئة التأمين، هيئة الأمن السيبراني)



إدارة الجودة والتطوير Quality & Development Management



7. قواعد عامة:

7.1 إنشاء الحسابات وإدارة صلاحيات الدخول:

- 7.1.1 يجب على إدارة تقنية المعلومات إنشاء الحسابات الإلكترونية الرسمية فقط بناءً على طلب معتمد من الإدارة المالكة للنظام، متضمناً اسم المستخدم، القسم، نوع الصلاحية، ومدة الصلاحية إن وجدت.
- 7.1.2 يُلزم بعدم إنشاء أو تفعيل أي حساب بدون تحقق من وجود حاجة تشغيلية فعلية وموافقة الجهة المالكة للنظام.
- 7.1.3 يجب تسجيل كافة الحسابات ضمن سجل إدارة الوصول الإلكتروني، ويُحدث هذا السجل بشكل فوري عند كل عملية إضافة أو تعديل.
- 7.1.4 يُلزم بتوثيق الحسابات التقنية غير المرتبطة بالأفراد (مثل: API / Integration Accounts) وربطها بخدمة محددة، ولا تُفعل إلا بموافقة من مدير تقنية المعلومات ومسؤول الأمن السيبراني.

7.2 مراجعة الصلاحيات:

- 7.2.1 يجب مراجعة كافة صلاحيات الدخول على الأنظمة بشكل ربع سنوي من قبل مشرف تقنية المعلومات، وبمصادقة الجهة المالكة للنظام. يُلزم بإلغاء الصلاحيات غير النشطة أو غير المستخدمة لمدة تزيد عن 60 يوماً.
- 7.2.2 في حال انتهاء العلاقة الوظيفية أو الانتقال الداخلي، يجب تعطيل جميع الحسابات فوراً خلال 4 ساعات كحد أقصى.
- 7.2.3 تُراجع صلاحيات الحسابات المؤقتة يومياً ويُبلغ أي وصول انتهت مدته تلقائياً.

7.3 دورة حياة الوصول:

- 7.3.1 يجب اتباع دورة حياة متكاملة لإدارة الوصول تشمل: التهيئة ← المراقبة ← الإلغاء.
- 7.3.2 يُلزم توثيق كل مرحلة من الدورة في سجل الوصول المعتمد، وتحديد المسؤول المنفذ والتاريخ.
- 7.3.3 يجب تحديد آلية إدارة طلبات الوصول العاجلة خارج أوقات العمل وتوثيقها بأثر رجعي في أول يوم عمل يلي الطلب.

7.4 التحكم في مستويات الوصول:

- 7.4.1 يجب تطبيق مبدأ أقل صلاحية (Least Privilege) في منح الصلاحيات لجميع المستخدمين.
- 7.4.2 تُحدد مستويات الوصول حسب الوظيفة، ويُمنع منح صلاحيات إدارية ما لم تقتضي الحاجة التشغيلية وتوثق بمبررات.
- 7.4.3 يُمنع استخدام حسابات إدارية عامة أو غير مخصصة باسم المستخدم الرسمي.
- 7.4.4 يجب تطبيق مبدأ فصل المهام (Segregation of Duties) عند توزيع الصلاحيات بحيث لا يُمنح المستخدم صلاحية تنفيذ ومراجعة أو اعتماد في نفس النظام دون رقابة مزدوجة.
- 7.4.5 لا يُسمح باستخدام أجهزة شخصية للوصول إلى الأنظمة إلا بعد تسجيلها وتفعيل رقابة MDM عليها وموافقة الأمن السيبراني.
- 7.4.6 لا تُمنح الصلاحيات إلا بموافقة مكتوبة من مشرف تقنية المعلومات وتوثيق اتفاقية دخول إلكترونية.
- 7.4.7 تُربط الصلاحيات بتاريخ انتهاء تلقائي وتعليق تلقائي بعد انقضاء المهلة المحددة.

7.5 التوثيق والمراقبة:

- 7.5.1 يجب تسجيل جميع محاولات الدخول، الناجحة والفاشلة، ومراجعتها يومياً باستخدام منصة SIEM.
- 7.5.2 يُحتفظ بسجلات الدخول لمدة لا تقل عن 12 شهراً لأغراض التدقيق والتحقيق في الحوادث.
- 7.5.3 تُعد تقارير امتثال شهرية وتُرفع إلى لجنة الأمن السيبراني DIB Information Security Committee.
- 7.5.4 في حال رصد دخول غير اعتيادي (مثل دخول ليلى، أو من IP غير معروف)، يجب تنبيه مسؤول الأمن السيبراني خلال ساعة واحدة وفتح تحقيق فوري.
- 7.5.5 يجب إنشاء سجل خاص لتعديلات الصلاحيات (Access Change Log) يتضمن: اسم المستخدم، الجهة الطالبة، نوع التعديل، السبب، اسم منفذ التعديل، وتاريخ التنفيذ.
- 7.5.6 عند رصد دخول غير اعتيادي منخفض الشدة (مثل تسجيل دخول من موقع غير معتاد دون اختراق)، يجب تنفيذ إجراءات تحقق إضافية مثل إعادة المصادقة، ومراقبة نشاط الحساب لمدة لا تقل عن 72 ساعة.

7.6 المصادقة والتوثيق:

- 7.6.1 يجب تفعيل المصادقة متعددة العوامل (MFA) لجميع الأنظمة التي تحتوي على معلومات سرية أو بيانات حساسة.
- 7.6.2 يُمنع مشاركة بيانات الدخول أو استخدام حسابات مشتركة بين أكثر من موظف.
- 7.6.3 تُستخدم كلمات مرور قوية وفق معيار الشركة ويجب تغييرها كل 90 يوماً.

- 7.6.4 يجب أن يتم الوصول عن بُعد عبر VPN مؤمن فقط، ويُمنع استخدام أدوات تحكم عن بُعد غير مصرح بها.
- 7.7 إنهاء الوصول:
- 7.7.1 يُلزم بإلغاء صلاحيات الدخول مباشرة في الحالات التالية:
- 7.7.1.1 انتهاء العلاقة الوظيفية
- 7.7.1.2 النقل الداخلي إلى قسم غير معني بالنظام
- 7.7.1.3 الإجازات الطويلة (أكثر من 30 يومًا)
- 7.7.2 يُمنع تعليق الحسابات دون إجراء حذف أو تعطيل فعلي.
- 7.8 إدارة الوصول للأنظمة السحابية:
- 7.8.1 يجب أن تخضع تطبيقات SaaS ونظم الحوسبة السحابية لنفس معايير إدارة الوصول الداخلية.
- 7.8.2 يُلزم بتوثيق الدخول عبر بروتوكولات آمنة (مثل SAML, OAuth).
- 7.8.3 يُمنع استخدام الحسابات الافتراضية التي يمنحها مزود الخدمة دون تقييد وتوثيق رسمي.
- 7.8.4 يُمنع استخدام الحسابات الافتراضية التي يمنحها مزود الخدمة إلا بعد ربطها بالمستخدم الفعلي وتسجيل صلاحياتها ضمن سجل إدارة الوصول.
- 7.9 صلاحيات الطوارئ:
- 7.9.1 يجب إنشاء حسابات صلاحيات طارئة (Break Glass) مخصصة تستخدم فقط في حالات الطوارئ القصوى.
- 7.9.2 يُشترط موافقة مكتوبة من مدير الأمن السيبراني لتفعيل الحساب.
- 7.9.3 تُلغى الصلاحيات مباشرة بعد الاستخدام، وتُعد تقرير مفصل يُراجع من لجنة الأمن السيبراني.
- 7.10 التدريب والوعي:
- 7.10.1 يُلزم جميع الموظفين بحضور دورة توعية ربع سنوية حول ضوابط إدارة الوصول.
- 7.10.2 يجب تدريب الموظفين الجدد على سياسات الوصول خلال أول أسبوع عمل.
- 7.11 الامتثال والمساءلة:
- 7.11.1 تُراقب الامتثال عبر تقارير شهرية من مشرف تقنية المعلومات ومسؤول الأمن السيبراني.
- 7.11.2 تُرفع التقارير إلى اللجنة الأمنية العليا لمراجعة المخالفات.
- 7.11.3 يُحاسَب أي موظف يتسبب في خرق لضوابط الوصول وفقًا للوائح الموارد البشرية والسياسات التأديبية.
- 7.11.4 يجب قياس الالتزام بتطبيق هذه السياسة من خلال تدقيق ربع سنوي، وتُعد تقرير تفصيلي بالنتائج والإجراءات التصحيحية.
- 7.11.5 يُلزم أي مستخدم خارجي من شركات التأمين أو الموردين بالخضوع لكافة الضوابط الواردة في هذه السياسة، ويُسجل حسابه كمستخدم مؤقت محدود الصلاحيات بموجب اتفاقية دخول معتمدة.

8. مسؤولية السياسة:

8.1 مشرف تقنية المعلومات

8.1.1 مسؤول عن تفعيل هذه السياسة، والإشراف على إدارة الحسابات والصلاحيات، وضمان حفظ السجلات.

8.2 مسؤول الأمن السيبراني:

8.2.1 مسؤول عن مراقبة الالتزام، ومراجعة التعديلات، والتحقيق في أي دخول مشبوه أو غير اعتيادي.

8.3 إحصائي تقنية المعلومات:

8.3.1 مسؤول عن تنفيذ التعديلات الفنية، وتوثيق عمليات الدخول، ومراجعة الحسابات.

8.4 الإدارة المالكة للنظام:

8.4.1 مسؤولة عن الموافقة على طلبات الوصول وتحديد نوع الصلاحية.

8.5 المستخدم:

8.5.1 مسؤول عن استخدام صلاحياته فقط في إطار ما هو مصرح به، والإبلاغ عن أي دخول غير معتاد أو استخدام خاطئ.

8.6 مسؤول الأمن السيبراني:

8.6.1 مسؤول عن تفعيل أنظمة المراقبة، التنوعية، التحقيق في الحوادث الأمنية، وضمان الامتثال الكامل للسياسة، ورفع تقارير دورية للإدارة العليا.

8.7 إدارة الالتزام والامتثال:

8.7.1 مسؤولون عن مراجعة مدى التزام الإدارات المختلفة بتطبيق الضوابط الأمنية على مستوى المستخدمين.

8.7.2 مسؤولون عن التحقق من وجود آلية فعالة للإبلاغ عن الحوادث التقنية والرد عليها بما يتوافق مع متطلبات الجهات الرقابية.

8.8 إدارة الجودة والتطوير:

8.8.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 إلحاقاً لتعميم المواصفات الفنية لنظام المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (197/2020)، بتاريخ

27/10/2020.

9.2 استخدام نظام المراقبة الرقمي في النقل والحفظ الأمن لتسجيلات وبيانات أجهزة المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي

(SAMA)، برقم (224/2021)، بتاريخ 24/10/2021.

9.3 التأكيد على الالتزام بالتعليمات الخاصة بحماية البيانات الشخصية للعملاء، الصادرة عن البنك المركزي السعودي (SAMA)، برقم

(44043873)، بتاريخ 18/12/2024.

9.4 أي تعاميم تخص السياسة من الجهات المشرعة.

10. حفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل

نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة دايمنود المُعت



إدارة الجودة والتطوير
Quality & Development Management

Diamond Insurance Broker

Access Management Policy

May 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY



Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



إدارة الجودة والتطوير Quality & Development Management

Article (1): This document and the information it contains are related to Al Wathiq Al Massiya Insurance Broker (Diamond). They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

Policy Information				
Policy Title	Access Management Policy			
Policy Status	Newly Issued			
Previous Policy Title	None			
Previous Policy Date	None			
Document Number	1ITM0012			
Next Review Date	Two years from the date of policy approval or as required			
Policy Owner	Information Technology Management			
Prepared by	Quality & Development Management			
Managements/Functions that Reviewed and Approved the Policy				
Management	Position	Name	Date	Signature
Regulatory Management	Legal and Compliance Manager	Turki Abdullah Al-Abdali	29/07/2025	
Policy Review Lead	Quality & Development Manager	Shaden Sultan Alotaibi	29/07/2025	
Policy Approval				
Senior Management	Managing Director	Badr Saad Al Shaya	29/07/2025	



إدارة الجودة والتطوير
Quality & Development Management

1. Introduction:

1.1 The Access Management Policy is a fundamental component of the company's technical governance framework. It aims to regulate and document the process of granting and managing user access privileges within the company's systems. This policy provides the organizational structure necessary to ensure secure and disciplined use of user accounts and to prevent unauthorized access or misuse of access privileges in the company's digital environment.

2. Policy Objective:

- 2.1 Al Wathiqah Al Massiya Insurance Broker Company (hereinafter referred to as "Diamond") affirms that the objective of this policy is to regulate the procedures for granting, modifying, and revoking access privileges to the company's technical systems. This ensures compliance with the Least Privilege Principle and Segregation of Duties.
- 2.2 The policy aims to minimize risks arising from account misuse or unauthorized access by documenting the full lifecycle of access privileges from creation to revocation. It also ensures compliance with regulatory requirements issued by relevant authorities in the Kingdom of Saudi Arabia.

3. Definitions

- 3.1 **Diamond:** Diamond Insurance Broker.
- 3.2 **User:** Any employee, trainee, consultant, vendor, or third party authorized to use any of the company's technical systems.
- 3.3 **Account:** A unique electronic identifier used to access a specific system and linked to a username and defined privileges.
- 3.4 **Privilege:** The level of control or functions that a user is permitted to perform within a system (e.g., view, edit, delete, approve).
- 3.5 **Access:** The process of a user logging into one of the company's systems using approved credentials to perform tasks.
- 3.6 **Temporary Access:** Access granted to a user for a limited period to perform specific tasks, which is automatically revoked after the defined period.
- 3.7 **External Account:** An account granted to an entity not part of the company's organizational structure (e.g., an insurance provider or service vendor) and managed under an access agreement.
- 3.8 **Least Privilege:** A security principle that requires users to be granted the minimum privileges necessary to perform their duties.
- 3.9 **Segregation of Duties:** A control measure ensuring that no single individual is given conflicting privileges that could allow misuse, such as both execution and approval within the same system.
- 3.10 **Privileged Account:** An account with elevated privileges, such as creating users or managing system configurations, subject to strict oversight.
- 3.11 **Break Glass Account:** An emergency-use account activated manually in critical situations and fully logged.
- 3.12 **Access Log:** An electronic log that records all successful or failed login attempts, as well as account and privilege changes.
- 3.13 **Access Change Log:** A detailed record of all access-related actions (granting, modifying, revoking), including the reason, date, and responsible party.
- 3.14 **MDM System (Mobile Device Management):** A system for managing and monitoring mobile devices that connect to the company's systems.

3.15 Compliance Review: A periodic audit process to verify user adherence to the Access Management Policy and address any violations.

4. Scope of Application:

4.1 This policy applies to all company systems and technologies, including: Customer Relationship Management (CRM) systems, Human Resources systems, insurance portal integrations, policy issuance systems, email, and systems connected to regulatory bodies such as the Saudi Central Bank (SAMA) and the Insurance Authority.

5. Related Management and Sectors:

5.1 Information Technology Management.

5.2 Cybersecurity Department.

6. Related Entities:

6.1 All entities wholly owned by Diamond.

6.2 Authorized technology providers

6.3 Regulatory bodies (Insurance Authority, National Cybersecurity Authority)



إدارة الجودة والتطوير
Quality & Development Management

7. General Rules:

7.1 Account Creation and Access Privilege Management:

- 7.1.1 The Information Technology function must only create official electronic accounts based on a valid request approved by the system owner. The request must include: username, business unit, access type, and duration (if temporary).
- 7.1.2 No account shall be created or activated unless a legitimate operational need exists and is approved by the system owner.
- 7.1.3 All accounts must be registered in the Electronic Access Management Register, which must be updated immediately upon each addition or change.
- 7.1.4 Non-personal technical accounts (e.g., API / Integration Accounts) must be documented and linked to a specific service. These accounts may only be activated with the approval of the IT Manager and the Cybersecurity Officer.

7.2 Privilege Review:

- 7.2.1 All access privileges must be reviewed quarterly by the IT Supervisor, with validation by the system owner. Inactive or unused privileges for more than 60 days must be revoked.
- 7.2.2 In case of employment termination or internal transfer, all related accounts must be disabled within a maximum of 4 hours.
- 7.2.3 Temporary accounts must be reviewed daily, and access must be revoked automatically upon expiry.

7.3 Access Lifecycle Management:

- 7.3.1 A complete access lifecycle must be followed: Provisioning → Monitoring → Revocation.
- 7.3.2 Each stage must be documented in the approved Access Log, including the responsible person and the date of action.
- 7.3.3 A defined process for emergency access requests outside business hours must be established and documented retroactively on the next working day.

7.4 Access Level Controls:

- 7.4.1 The Least Privilege principle must be applied to all user accounts.
- 7.4.2 Access levels must be assigned based on job role. Administrative access must only be granted when operationally justified and properly documented.
- 7.4.3 Use of generic or non-personal privileged accounts is strictly prohibited.
- 7.4.4 The Segregation of Duties principle must be applied — no user shall have conflicting privileges (e.g., execution and approval) without dual control.
- 7.4.5 Use of personal devices to access systems is prohibited unless the device is registered, monitored via MDM, and approved by the Cybersecurity function.
- 7.4.6 No access privileges may be granted without written approval from the IT Supervisor and a signed Electronic Access Agreement.
- 7.4.7 All access privileges must have an automatic expiration date, after which access is suspended unless renewed.

7.5 Logging and Monitoring:

- 7.5.1 All login attempts (successful and failed) must be recorded and reviewed daily using a SIEM platform.
- 7.5.2 Access logs must be retained for a minimum of 12 months for audit and incident investigation purposes.

- 7.5.3 Monthly compliance reports must be submitted to the DIB Information Security Committee.
- 7.5.4 In case of abnormal access (e.g., late-night login or unknown IP), the Cybersecurity Officer must be alerted within one hour and an immediate investigation must be initiated.
- 7.5.5 A dedicated Access Change Log must be maintained, including, username, requesting party, type of change, justification, executor's name, and execution date.
- 7.5.6 If a low-risk abnormal login is detected (e.g., login from an unusual location without compromise), additional verification procedures must be applied — such as re-authentication and monitoring of the account activity for no less than 72 hours.
- 7.6 Authentication and Credential:
 - 7.6.1 Multi-Factor Authentication (MFA) must be enforced on all systems containing confidential or sensitive data.
 - 7.6.2 Sharing of login credentials or using shared accounts is strictly prohibited.
 - 7.6.3 Strong passwords must be used in accordance with company standards and must be changed every 90 days.
 - 7.6.4 Remote access must only be performed via a secure VPN. Use of unauthorized remote control tools is strictly prohibited.
- 7.7 Access Termination:
 - 7.7.1 Access privileges must be immediately revoked in the following cases:
 - 7.7.1.1 End of employment relationship
 - 7.7.1.2 Internal transfer to a business unit not related to the system
 - 7.7.1.3 Long-term leave (more than 30 days)
 - 7.7.2 It is prohibited to suspend accounts without proper deactivation or deletion.
- 7.8 Cloud Systems Access Management:
 - 7.8.1 All SaaS applications and cloud computing platforms must adhere to the same internal access management standards.
 - 7.8.2 Authentication must be documented through secure protocols (e.g., SAML, OAuth).
 - 7.8.3 Default accounts provided by service providers may not be used unless formally documented and restricted.
 - 7.8.4 Default accounts must be linked to an actual user, and their privileges must be logged in the Access Management Register.
- 7.9 Emergency Privileges:
 - 7.9.1 Emergency privilege accounts (Break Glass Accounts) must be created and used only during extreme emergencies.
 - 7.9.2 Written approval from the Cybersecurity Officer is required before activating such accounts.
 - 7.9.3 Access must be revoked immediately after use, and a detailed report must be submitted for review by the Cybersecurity Department.
- 7.10 Training and Awareness:
 - 7.10.1 All employees must attend a quarterly awareness session covering access management controls.
 - 7.10.2 New employees must be trained on access policies within the first week of employment.
- 7.11 Compliance and Accountability:

- 7.11.1 Compliance is monitored through monthly reports prepared by the IT Supervisor and the Cybersecurity Officer.
- 7.11.2 Reports are submitted to the Executive Security Committee for review of violations.
- 7.11.3 Any employee who causes a breach of access controls is held accountable according to HR regulations and disciplinary policies.
- 7.11.4 A quarterly audit must be conducted to measure compliance with this policy, and a detailed report of findings and corrective actions must be prepared.
- 7.11.5 Any external user (e.g., insurance companies, vendors) must fully comply with the requirements of this policy. Their account must be registered as a temporary limited-access user under a formally approved access agreement.



إدارة الجودة والتطوير Quality & Development Management

8. Policy Responsibility:

8.1 IT Supervisor:

- 8.1.1 Responsible for enforcing this policy, supervising account and privilege management, and ensuring proper record-keeping.

8.2 Cybersecurity Officer:

- 8.2.1 Responsible for monitoring compliance, reviewing privilege modifications, and investigating suspicious or abnormal access.
- 8.2.2 Responsible for enabling monitoring tools, conducting awareness sessions, investigating security incidents, ensuring full policy compliance, and submitting periodic reports to top management.

8.3 IT Specialist:

- 8.3.1 Responsible for performing technical changes, logging access activities, and reviewing accounts.

8.4 System Owner:

- 8.4.1 Responsible for approving access requests and defining the appropriate level of privilege.

8.5 User:

- 8.5.1 Responsible for using privileges only within authorized boundaries and reporting any suspicious access or misuse.

8.6 Compliance and Regulatory Affairs:

- 8.6.1 Responsible for reviewing departmental adherence to security controls at the user level.
- 8.6.2 Responsible for verifying the existence of an effective incident reporting and response mechanism in alignment with regulatory requirements.

8.7 Quality and Development Management:

- 8.7.1 Responsible for ensuring enforcement of this policy through periodic reviews and audits.

9. Related Circulars and Instructions:

- 9.1 As per the Technical Specifications Circular for CCTV Systems issued by the Saudi Central Bank (SAMA), Ref. No. (202010/197), dated 27/10/2020.
- 9.2 As per the circular on the use of digital surveillance systems for secure transmission and storage of CCTV data, issued by SAMA, Ref. No. (202110/224), dated 24/10/2021.
- 9.3 As per the circular on Personal Data Protection for Customers, issued by SAMA, Ref. No. (44043873), dated 18/12/2024.
- 9.4 Any future circulars related to this policy issued by regulatory authorities.

10. Policy Retention:

- 10.1 The non-copyable digital version of the approved policy shall be stored in the HR system and made accessible to relevant departments.
- 10.2 A hard copy of the approved policy shall be retained by the Quality and Development Department for the legally defined retention period as specified in the Document Aging Manual and then formally archived.

11. Policy Violation:

- 11.1 Any violation of this policy shall be subject to the penalties outlined in Diamond's approved Disciplinary Regulations.